PULSE AI

Security Self-Assessment Report

FinTechathon 2026, Topic E

1. Scope

Backend API (FastAPI), frontend (React), Supabase Postgres, AI agents, n8n workflows. This assessment is a self-review by the team; no external penetration test was performed.

2. Permission-tier implementation

Capability	VIEWER	ACCOUNTANT	FINANCE_MANAGER	OWNER	Platform admin
View dashboard, forecast, copilot answers	Yes	Yes	Yes	Yes	No (admin console only)
Run simulations	Yes	Yes	Yes	Yes	No
Import data	No	Yes	Yes	Yes	No
Propose actions (incl. via agents)	No	Yes	Yes	Yes	No
Approve and execute actions	No	No	Yes	Yes	No
Manage members and organization	No	No	No	Yes	No
Review / suspend accounts, view audit	No	No	No	No	Yes

> Approval and execution thresholds are as enforced in `backend/app/api/actions.py` and `app/api/deps.py`. Check the code for the exact minimum role of each endpoint.

3. Controls

Control	Implementation	Status
Authentication	JWT bearer tokens (python-jose), bcrypt password hashing	IMPLEMENTED
Email verification	6-digit code, HMAC-hashed at rest, 10 min TTL, 5 attempts, 60 s resend cooldown	IMPLEMENTED
Account approval	Accounts approved after verified email code; admins can suspend; reviews stored in AccountReview	IMPLEMENTED
Tenant isolation	Every financial query filtered by organization_id after membership check	IMPLEMENTED
Role-based access	OWNER > FINANCE_MANAGER > ACCOUNTANT > VIEWER enforced by require_role	IMPLEMENTED
Agent tool permissions	Risk Guardian denies propose_invoice_reminder below ACCOUNTANT (ToolDenied)	IMPLEMENTED
Human approval	PROPOSE, APPROVE, EXECUTE; unapproved or repeated execution returns 409	IMPLEMENTED
Honest status	Actions without a configured webhook are QUEUED, never reported SENT	IMPLEMENTED
Audit trail	AuditLog for approvals, executions and admin decisions; admin activity log page	IMPLEMENTED
SSRF guard	Google Sheets export URL rebuilt server-side; only docs.google.com fetched	IMPLEMENTED
Secrets	Keys only in backend/.env (gitignored); not in repo or submission ZIP	IMPLEMENTED
Webhook auth	n8n webhooks require a shared header secret	IMPLEMENTED
LLM grounding	Numbers come from deterministic tools; deterministic fallback if the LLM fails	IMPLEMENTED
Input validation	Pydantic schemas, Decimal money, import column validation	PARTIAL
Transport security	HTTPS depends on deployment; local dev runs over HTTP	PARTIAL
CORS	Restricted to configured frontend origins	PARTIAL
Rate limiting / brute force	Only OTP attempt limits; no global login rate limiting	PLANNED
MFA for owners/admins	Not implemented	PLANNED
Encryption of financial fields at rest	Relies on Supabase disk encryption only	PLANNED
Token revocation / refresh	Short-lived JWT only; no revocation list	PLANNED
Dependency and SAST scanning in CI	Not set up	PLANNED

4. Verified behaviour

Captured against the running backend (see execution_evidence/api_core_scenario.md): unauthenticated request returns 401; executing an unapproved action returns 409; approval by

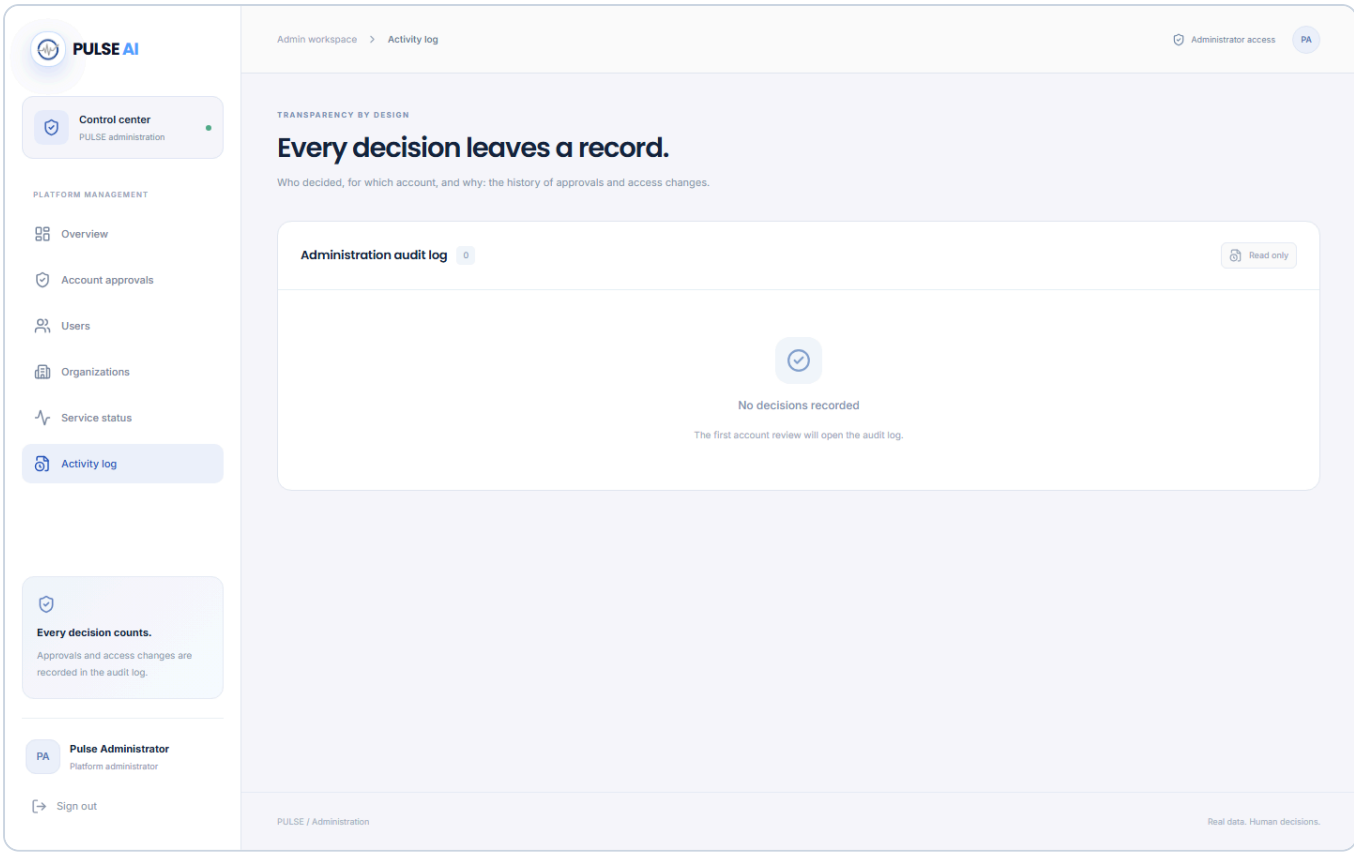
OWNER returns 200; execution without webhook returns QUEUED; repeated execution returns 409. Agent permission denial is covered by automated tests (87 passing).

5. Known-risk list

#	Known risk	Impact	Mitigation status
R1	Credential stuffing on /auth/login	Account takeover	PLANNED: rate limiting, MFA
R2	Prompt injection through imported descriptions or chat	Misleading answer	PARTIAL: tools are read-only or create PENDING_APPROVAL only; numbers from engines
R3	Sensitive financial data sent to the LLM provider	Privacy	PARTIAL: only tool results for the user's org; provider can be disabled (deterministic mode)
R4	Leaked JWT used until expiry	Session hijack	PLANNED: refresh tokens and revocation
R5	Misconfigured webhook secret	Spoofed workflow calls	PARTIAL: header secret required; rotation manual
R6	Forecast error on irregular businesses	Wrong decision	MITIGATED: known vs uncertain split, human approval, rescue plans labeled as simulations
R7	Malformed or huge import files	Bad data, resource use	PARTIAL: preview, mapping, validation; size limits to harden
R8	Dependency vulnerabilities	Varies	PLANNED: pip-audit / npm audit in CI

6. Data handling

Submission evidence uses the Northstar Studio company only. Identifiers, emails and tokens are masked in logs and screenshots. No .env file or credential is included in the submission package.



Admin activity log (personal emails masked)